

中华人民共和国通信行业标准

YD/T [×××××]—202X
[代替 YD/T]

电信网和互联网数据安全日志审计指南

The log audit guidance for data security in telecommunications and Internet

[点击此处添加与国际标准一致性程度的标识]

(报批稿)

2021. 2. 1

[××××]-[××]-[××]发布

[××××]-[××]-[××]实施

中华人民共和国工业和信息化部 发布

目 次

前 言III

1 范围4

2 规范性引用文件4

3 术语和定义4

4 缩略语5

5 日志审计基本方法5

 5.1 建立审计制度5

 5.2 设立审计岗位5

 5.3 确定审计对象范围5

 5.4 明确审计方式5

 5.5 形成审计报告6

 5.6 跟踪问题整改情况6

 5.7 开展安全评估6

6 数据生命周期日志审计方法6

 6.1 数据采集阶段6

 6.2 数据传输阶段6

 6.3 数据存储阶段7

 6.4 数据使用阶段7

 6.5 数据开放共享阶段7

 6.6 数据销毁阶段8

 6.7 数据访问和操作账号分配和使用8

 6.8 数据存储设备8

7 日志审计技术配套能力建设方法8

 7.1 功能建设实施方法8

 7.1.1 审计资源管理功能8

 7.1.2 审计策略管理功能9

 7.1.3 自动化审计功能9

 7.1.4 溯源追溯功能9

 7.1.5 结果管理功能9

 7.2 安全保障实施方法10

 7.2.1 访问控制10

 7.2.1.1 账号管理10

 7.2.1.2 权限管理10

 7.2.1.3 认证鉴权10

7.2.1.4 远程管理10

7.2.2 日志记录11

7.2.3 时间同步11

7.2.4 审计过程保护11

7.2.5 审计结果保护11

7.2.6 安全审计11

7.2.7 系统冗余11

7.2.8 状态监测11

7.2.9 风险管理11

附 录 A（资料性）数据安全日志审计报告模板.....13

参考文献15

前 言

本文件按照GB/T 1.1—2020《标准化工作导则 第1部分：标准化文件的结构和起草规则》的规定起草。

本文件是“电信网和互联网数据安全”系列标准之一。该系列标准预计结构及名称如下：

- 《电信网和互联网数据安全通用要求》（YD/T 3802-2020）
- 《电信网和互联网数据安全评估规范》（YD/T 3956-2021）
- 《电信网和互联网数据安全评估技术实施指南》
- 《电信网和互联网数据资产识别与梳理技术实施指南》
- 《电信网和互联网数据安全日志审计指南》（本文件）
- 《电信网和互联网数据生命周期日志留存指南》

请注意本文件的某些内容可能涉及专利。本文件的发布机构不承担识别这些专利的责任。

本文件由中国通信标准化协会提出并归口。

本文件起草单位：中国信息通信研究院、数据通信科学技术研究所、中国移动通信集团有限公司、北京神州绿盟科技有限公司、中安威士（北京）科技有限公司、北京东方通网信科技有限公司、恒安嘉新(北京)科技股份公司、北京天融信网络安全技术有限公司。

本文件主要起草人：庞妹、张媛媛、郭建南、姜宇泽、张则阳、魏薇、张琳琳、叶东岳、刘晓、范晓杰、江为强、戴林、梁步庭、薛南、刘为化、王龔、朱广红。

电信网和互联网数据安全日志审计指南

1 范围

本文件规范了基于数据生命周期各环节数据访问和操作日志的审计工作，包括日志审计组织方式、审计对象和重点、审计工作技术支撑条件等，重点从应对组织机构内外部数据安全风险出发，场景化梳理了数据安全日志审计的策略。

本文件主要适用于电信服务和互联网信息服务提供者，指导其在服务提供过程中为保障数据安全而开展的日志审计工作。本文件也适用于组织机构中具有数据安全日志审计技术能力的平台系统规划、建设与改造，以及数据安全评估服务机构等对数据安全日志审计有效性的评估评测。

2 规范性引用文件

下列文件中的内容通过文中的规范性引用而构成本文件必不可少的条款。其中，注日期的引用文件，仅该日期对应的版本适用于本文件；不注日期的引用文件，其最新版本（包括所有的修改单）适用于本文件。

YD/T 3956-2021 《电信网和互联网数据安全评估规范》

YD/T XXXX-XXXX 《电信网和互联网数据生命周期日志留存指南》

YD/T XXXX-XXXX 《电信网和互联网数据安全评估技术实施指南》

3 术语和定义

下列术语和定义适用于本文件。

3.1

日志审计 log audit

针对数据生命周期各环节数据访问和操作日志的监控和审计，保证对数据的访问和操作能够得到有效的控制，以实现数据生命周期各环节中可能存在的未授权访问、数据滥用、数据泄露等安全风险的防控。

3.2

审计事件 audit events

基于组织机构内可能引发数据安全风险或事件的场景（如未授权访问、数据滥用、数据泄露等）细化出的日志审计项目，能够据此对风险隐患进行识别发现。

3.3

审计资源 audit resources

生成或存储数据安全相关日志的访问实体，包括应用资源和系统资源。

4 缩略语

下列缩略语适用于本文件。

CPU	中央处理器	Central Processing Unit
HTML	超级文本标记语言	Hyper Text Markup Language
IC	集成电路	Integrated Circuit
IP	互联网协议	Internet Protocol
VPN	虚拟专用网络	Virtual Private Network

5 日志审计基本方法

5.1 建立审计制度

建立数据安全日志审计管理制度，明确数据安全日志审计工作组织部门和相关执行部门，明确审计目的、审计对象、审计内容、审计策略、审计方式、审计操作方法、审计结果规范、审计问题整改跟踪等内容。审计的目的应全面围绕识别数据未授权访问、数据滥用、数据泄露等内外数据安全风险和违规操作行为。

5.2 设立审计岗位

企业数据安全管理部门或数据处理活动相关平台系统负责部门，应设立数据安全日志审计的岗位、配备相关人员，负责对数据生命周期各阶段数据访问和操作日志进行审计。

5.3 确定审计对象范围

审计对象应完整覆盖业务及平台系统数据访问日志、操作日志、事件告警日志、应用日志、网关日志，以及应用系统日志、数据库日志、网络安全设备日志和安全日志等中涉及数据访问与操作行为的日志。

审计内容应结合日志记录情况尽可能详尽的显示数据访问与操作行为发生的具体特征，包括但不限于：时间、次数、数据的源、行为目标、操作类型、数据敏感判断、响应内容、返回结果内容、执行时间（毫秒）、响应状态、影响范围、匹配的策略、风险等级。

结合组织机构数据分类分级情况将高级别数据的访问和操作行为，以及大规模存储和处理高级别数据的平台系统纳入重点审计范围。

5.4 明确审计方式

应明确数据日志审计工作开展的方式，如实时监控审计、定期批量审计、人工审计核查等。采用实时监控审计方式的，宜支持审计事件的策略配置，能够对发现的风险情况实施告警和处置。

应结合日志记录情况提供多种关联分析方法，包括但不限于：相同源IP的事件关联分析、相同目的IP的事件关联分析、相同事件类型的关联分析以及基于规则的事件关联分析、统计关联分析和漏洞关联分析。能够通过关联分析更加准确地定义和定位安全事件。

掌握数据生命周期各阶段数据安全风险行为识别方法，按照对应方法实施日志审计工作。数据生命周期日志审计方法指引详见第6章。

5.5 形成审计报告

实施数据安全日志审计后留存审计记录，宜形成数据安全审计报告（见附录A）。审计数据记录内容至少包括：审计时间、实施主体、审计对象、审计事件、审计判定过程和审计结果等，并根据审计情况标注风险问题和跟踪处理结果。

5.6 跟踪问题整改情况

组织对审计发现的风险问题进行研判，针对确属可引发企业数据安全风险隐患的，及时对相关行为进行告警、中断、或处置，提出整改方案并推进落实，对改进措施效果进行持续跟踪审核，视情况调整企业数据安全保护措施；针对已构成数据安全事件的，及时启动应急响应工作。

5.7 开展安全评估

按YD/T 3956-2021《电信网和互联网数据安全评估规范》5.7章节和YD/T XXXX-XXXX《电信网和互联网数据安全评估技术实施指南》5.7章节的规定，定期对日志审计工作的有效性进行评估和完善。

6 数据生命周期日志审计方法

6.1 数据采集阶段

本阶段审计工作按 YD/T XXXX-XXXX《电信网和互联网数据生命周期日志留存指南》7.1 章节的规定，关注数据采集行为日志记录、停止采集行为日志记录等，重点识别数据采集渠道、采集数据质量、数据采集连续性等安全风险。本阶段将下列情形纳入审计事件是至关重要的：

- a) 引入未经授权或非法数据源：重点审计日志记录中采集源新增或变化、采集方式变化、采集数据类型新增或变化、异常数据采集频次、采集授权记录为否等情况。
- b) 恶意虚假数据采集：重点审计日志记录中数据源新增或变化、异常数据格式、异常数据量级等情况。
- c) 数据采集异常中断：重点审计日志记录中数据源减少或变化、采集数据量级减少、采集时间记录异常等情况。
- d) 未执行数据停止采集操作：结合业务下线和账号注销场景，重点审计日志记录中采集源和采集目的等情况。

6.2 数据传输阶段

本阶段审计工作按 YD/T XXXX-XXXX《电信网和互联网数据生命周期日志留存指南》7.2 章节的规定，关注传输行为日志、传输接口调用、跨境传输日志等，重点识别数据传输链路安全风险。本阶段将下列情形纳入审计事件是至关重要的：

- a) 数据传输通道安全性低：重点审计日志记录中不安全的网络传输通信协议日志告警、传输方式变化（如专线传输变更为公共互联网传输）等情况。
- b) 非授权数据传输：重点审计日志记录中传输源/目的新增或变化、异常数据传输时间段、新增非信任（对端）目的地址、异常数据量级等情况。

- c) 超出业务需求范围传输数据：重点审计日志记录中异常数据量级、数据类型新增等情况。
- d) 跨境传输情形：重点审计日志记录中（对端）目的地址为境外或国际出入口的情况。

6.3 数据存储阶段

本阶段审计工作按 YD/T XXXX-XXXX《电信网和互联网数据生命周期日志留存指南》7.3 章节的规定，关注数据库操作日志、存储介质使用日志、数据备份日志、网络设备日志等，重点识别内外部数据窃取、数据被篡改、数据损毁或丢失、数据无法恢复等安全风险。本阶段将下列情形纳入审计事件是至关重要的：

- a) 数据存储介质异常接入：重点审计日志记录中终端设备接入告警事件、存储介质插拔记录、数据本地终端下载行为记录等。同时关注数据存储介质的获取（购买）、登记、审批、使用、维护、升级、标记和销毁等记录。
- b) 高敏感级数据明文存储：重点审计日志记录中数据识别结果异常告警或数据存储请求结果失败等情况。
- c) 异常静态数据访问或操作行为：重点审计日志记录中对数据字段的查询、新增、删除、修改等数据库操作日志，审计记录中数据库告警日志；新增、非信任或非授权操作者（账号、IP、终端设备）；批量数据访问行为、定义的禁止访问行为；执行对象属高敏感级数据类别、非正常执行时间（段）、操作被阻断或未成功等状态、异常数据访问量级等情况。
- d) 数据备份冗余机制失效：重点审计数据备份日志记录缺失、数据备份有效性验证告警等情况，同时审计数据备份日志中备份频率降低、备份数据量级不足等情况。

6.4 数据使用阶段

本阶段审计工作按 YD/T XXXX-XXXX《电信网和互联网数据生命周期日志留存指南》7.4 章节的规定，关注数据库操作日志、应用系统日志、数据脱敏日志、外围设备使用日志等，重点识别内部异常操作行为。本阶段将下列情形纳入审计事件是至关重要的：

- a) 数据越权或超范围使用行为：重点审计日志记录中数据访问操作告警、数据访问权限申请和审批记录、企业内部数据接口调用情况等。同时，搭配企业数据访问权限分配表审计数据访问日志记录。
- b) 数据未授权使用行为：重点审计日志记录中新增或切换数据操作账号、账号授权情况，账号使用者为组织机构外部人员的结合数据安全保密协议签订情况进行审计。
- c) 异常数据加工行为：重点审计日志记录中异常数据操作时间、异常数据量的数据加工、分析、统计行为等情况。
- d) 关键数据操作行为：重点审计日志记录中数据匿名化、数据脱敏、批量数据查询、批量数据读取、数据导入/导出、高敏感数据使用操作、数据使用媒介标识（如查询系统、数据分析系统的 IP 或名称等）异常等情况。
- e) 测试数据生成行为：重点审计日志记录中使用未脱敏的生产数据生成测试数据的情况。

6.5 数据开放共享阶段

本阶段审计工作按 YD/T XXXX-XXXX《电信网和互联网数据生命周期日志留存指南》7.5 章节

的规定，关注外部数据接口日志、网络安全设备日志、网关日志、应用系统日志等，重点识别外部数据窃取风险、未授权数据共享行为、敏感数据不正当披露行为。本阶段将下列情形纳入审计事件是至关重要的：

- a) 外部数据窃取行为：重点审计日志记录中网络安全设备日志告警情况，报告以及非信任数据接口调用地址、接口频繁调用等情况。
- b) 违规数据共享行为：重点审计日志记录中新增非信任（对端）目的地址、异常数据接口调用时间、异常数据量级、异常接口数据传送频率。同时，结合用户授权同意情况审计用户个人信息共享情况。
- c) 高敏感数据共享行为：重点审计日志记录中高敏感等级数据共享情况。
- d) 新增数据合作方行为：重点审计日志记录中新增（对端）目的地址
- e) 敏感数据披露行为：重点审计日志记录中数据展示记录情况。

6.6 数据销毁阶段

本阶段审计工作按 YD/T XXXX-XXXX《电信网和互联网数据生命周期日志留存指南》7.6 章节的规定，关注数据库（数据及结构）操作日志、存储介质使用日志等，重点识别数据超期留存、数据异常销毁等风险。本阶段将下列情形纳入审计事件是至关重要的：

- a) 数据不当或超期留存：重点审计日志记录中数据库操作日志中的删除行为，包括删除方式、删除数据类型、删除数据量级、操作行为结果等，对需销毁数据及其副本内容的删除效果进行验证。
- b) 数据异常销毁：重点审计日志记录中数据库操作日志中的数据（库、表）删除行为，包括数据批量删除，及非授权删除行为操作者（账号、IP）、授权情况为否、操作时间（中断情况）异常等情况。

6.7 数据访问和操作账号分配和使用

重点审计系统操作日志记录中涉及数据访问和操作账号分配和使用的行为，发现沉默账号、一人多账号、离职账号、账号使用人变更、异常或违规授权权限、操作或流程审批人异常或变更、审批人和申请人属同一账号、授权时长超长等情况。

6.8 数据存储设备

重点审计数据库、主机等资源使用基础日志，发现资源长时间未登录使用（处于沉默状态）等情况。

7 日志审计技术配套能力建设方法

7.1 功能建设实施方法

7.1.1 审计资源管理功能

审计资源的管理是利用技术能力开展审计工作的基础，具备以下能力是十分必要的：

- a) 具备对单个资源、资源组的生命周期管理功能，包括增加、修改、查询、删除等。
- b) 具备对资源组的批量操作功能，包括批量导入、导出及删除等。

- c) 具备对资源的多种组合条件查询功能。
- d) 具备从企业其他资源管理平台同步资源的功能。
- e) 具备从网络流量中发现资源的功能。

7.1.2 审计策略管理功能

审计策略的管理和配置具备以下能力是十分必要的：

- a) 支持根据组织机构数据分类分级情况，对高敏感数据类型进行定义。
- b) 支持对各类风险隐患和安全事件的审计参数配置，如数据量级阈值、数据类型、安全/非安全的数据传输协议、正常/异常时间段、信任/非信任地址、指定访问时间限制、数据访问与操作行为的定义等。
- c) 支持包括告警、中断、人工处置等针对各类审计处置结果的策略配置，审计事件告警策略支持屏幕报警、邮件告警、短信告警等方式之一。

7.1.3 自动化审计功能

通过实现以下功能，是具备自动化安全审计策略配置十分必要的基础能力：

- a) 能够按照单个用户实现用户画像从而形成用户日常数据操作和访问行为基线。
- b) 支持按照指定时间范围或指定数据量级的日志进行学习分析，形成正常日志行为模型。比如提供数据访问频次、访问时间、访问流量、访问账号（IP）、访问数据范围、访问较敏感高级别系统、数据接口调用等情况统计分析。
- c) 能够按照实时记录的日志信息进行模型增量训练和校正，保障模型的准确性和实时性。
- d) d. 能够自动发现新增日志。

7.1.4 溯源追溯功能

通过实现以下功能，是具备对审计发现风险隐患和事件开展溯源追溯十分必要的基础能力：

提供多维度统计、分析能力，包括：对象统计、风险统计、行为统计等，其中对象统计功能，可对敏感对象的访问行为、操作行为做统计、分析，可定向追溯风险访问来源。

7.1.5 结果管理功能

对审计结果的管理满足如下要求是至关重要的：

- a) 能够按单个资源、资源组实现审计结果统计。
- b) 能够按用户实现审计结果统计。
- c) 能够按事件类型实现审计结果统计。
- d) 支持审计记录保存时限设置。

具有日志审计功能的系统或平台模块应能够把风险隐患和事件分析结果生成审计记录，审计记录内容应至少包括：审计时间、审计对象、审计主体或其标识、审计事件内容、审计结果等。审计记录满足以下要求是至关重要的：

- a) 报表内容可定制。
- b) 报表包括文字和图像信息，可实现对审计结果的图像可视化呈现。
- c) 报表导出格式至少支持 HTML、PDF、WORD、EXCEL 等通用文件格式中的一种。
- d) 报表可周期性报送，如当天、当周、当月、当年以及定义时间跨度报表。

7.2 安全保障实施方法

7.2.1 访问控制

7.2.1.1 账号管理

具有日志审计功能的系统或平台模块账号管理满足以下要求是至关重要的：

- a) 任何账号都具备全局唯一标识。
- b) 满足实名制要求，能够匹配到个人，避免存在账号共享。

密码管理满足如下要求是十分必要的：

密码长度不少于 8 位，至少包括数字、大小写字母、特殊字符等至少 3 种组合。

7.2.1.2 权限管理

根据日志审计工作需求合理设置多个用户角色，如系统超级管理员、系统管理员、系统审计员、业务管理员、运维人员等，权限设置符合最小特权和权限分离原则。

7.2.1.3 认证鉴权

向审计系统登录用户提供除口令鉴别以外的其他身份鉴别机制是十分必要的，至少包括以下一种：

- a) 电子签名或证书鉴别；
- b) 智能 IC 卡鉴别；
- c) 生物特征识别技术，如指纹、虹膜等；
- d) 短信验证；
- e) 其他鉴别机制。

审计系统配置鉴别失败处理策略是十分必要的，用户鉴别尝试连续失败达到设定的次数后，阻止用户进一步的鉴别请求；最大失败次数仅由授权管理员用户设定。

审计系统配置用户登录超时锁定或注销策略是十分必要的，用户在设定的时间段内没有任何操作的情况下，终止其当前管理会话，需要再次进行身份鉴别才能够重新进行管理操作。最大超时时间仅由授权用户设定。

7.2.1.4 远程管理

具有日志审计功能的系统或平台模块对远程访问具备策略管理能力是十分必要的，包括但不限于：

- a) IP 地址限制；

- b) VPN 认证限制等；
- c) 应对远程传输获取审计结果数据进行保护，保护远程传输审计结果数据的保密性及完整性。

7.2.2 日志记录

具有日志审计功能的系统或平台模块具备生成自身安全日志的能力是十分重要的，日志记录包括以下事件：

- a) 认证鉴别，包括认证成功、认证失败、超时锁定、注销、鉴别失败处置等，
- b) 用户和角色的增加、删除、修改；
- c) 审计策略的增加、删除、修改、部署；
- d) 时间同步；
- e) 其他事件。

自身安全日志记录的内容包括：日期、时间、事件主体、事件客体、事件描述等。

7.2.3 时间同步

具有日志审计功能的系统或平台模块具备与时钟服务器时间同步功能是十分必要的，确保审计系统时钟同步状态正常。

7.2.4 审计过程保护

具有日志审计功能的系统或平台模块支持审计过程保护功能、避免未授权用户中断审计过程是十分必要的。

7.2.5 审计结果保护

具有日志审计功能的系统或平台模块支持审计结果保护功能、避免审计结果被篡改和未授权访问是十分必要的。

7.2.6 安全审计

具有日志审计功能的系统或平台模块支持自身日志记录的安全审计是十分必要的，并具备将事件分析结果生成审计记录的能力。

7.2.7 系统冗余

具有日志审计功能的系统或平台模块具备冗余保护，网络、设备及系统应避免单点故障是十分必要的，如采取分布式部署、主备冗余等方式。

7.2.8 状态监测

具有日志审计功能的系统或平台模块具备自身使用资源状态实时监控能力是十分必要的，包括但不限于 CPU、内存、流量等资源监测，支持对监测资源的实时可视化呈现是至关重要的。

7.2.9 风险管理

具有日志审计功能的系统或平台模块应根据主管部门要求，定期开展安全风险评估，及时发现安全风险隐患并落实安全加固。

附 录 A
(资料性)
数据安全日志审计报告模板

(封面)

(企业简称) 数据安全日志审计报告

部门/业务/系统名称: ××××

日志审计员: ×××

(部门/业务/系统名称)
年 月

1 数据安全日志审计范围

1.1 审计资源范围

【应对本次审计所覆盖的设备、系统资源进行说明，清晰说明审计覆盖的业务、系统等资源范围，以及资源相关的责任部门。】

1.2 审计日志时间范围

【应对本次审计所覆盖的日志时间范围进行说明，明确审计的日志起止时间。】

1.3 XX

【可根据企业审计策略要求对本次重点审计事件范围或数据生命周期阶段等设置独立小节进行描述说明。】

2 审计人员及审计时间

日志审计员：XXX

审计时间范围：XXXX 年 XX 月 XX 日-XXXX 年 XX 月 XX 日

3 数据安全审计事件分析

【可根据数据生命周期进行小节划分，分别从各阶段数据安全异常或关键事件进行数据统计、分析，或根据事件类别进行小节划分，分别对各类数据安全异常或关键事件进行数据统计、分析，应列出所有异常、需要人工确认的事件，如条目过多，应采用添加文件对象或附件等方式纳入审计报告】

4 数据安全审计结果确认情况

【对第3章需要人工确认的事件进行说明，如本次审计中无需要人工确认的事情，本节可省略。】

5 数据安全审计总结

【对本次审计总体情况进行简要总结。】

参 考 文 献

- [1] 《中华人民共和国网络安全法》
 - [2] 工业和信息化部令 第24号 《电信和互联网用户个人信息保护规定》
 - [3] GB/T 37988-2019 《信息安全技术 数据安全能力成熟度模型》
 - [4] GB/T 20945-2013 《信息安全技术 信息系统安全审计产品技术要求和测试评价方法》
 - [5] YD/T 3802-2020 《电信网和互联网数据安全通用要求》
-